

Security Now! #1082 - 06-09-26

The Malicious Use of AI

This week on Security Now!

- Was a US law firm right to pay a \$20 million ransom?
- Could Cisco have yet another SD-WAN 0-day in the wild?
- Why is it so difficult to author secure PHP code?
- Teens use "WeedHack" to spy and attack each other.
- Researchers create the first AI-enabled Internet worm.
- Google Chrome pops-up "Shop with confidence." What?!?
- The discovered and irresponsibly disclosed HTTP/2 Bomb.
- What Anthropic learns from their past year of Claude abuse: It's bad.

There may be hope for humanity after all



Security News

US law firm pays \$20 million ransom

The large law firm Weil Gotshal & Manges, which reported more than \$2 billion dollars in revenue last year, recently paid a \$20 million ransom in order to prevent the release of their confidential client data. The company said that their client's confidential data was stolen from an external cloud storage site earlier this year by a group known as the Silent Ransom Group. The FBI sent out a private industry alert last year warning that this Silent Ransom Group had been specifically targeting US law firms in extortion campaigns.

What I appreciate about this is the strategic value of targeting law firms for extortion. Everyone knows I'm not endorsing the practice — far from it. But I think that high-end law firms are an interesting and clever ransom target.

We've been seeing and have reported on the surprising and welcome dramatic decline in the percentage of ransoms that are being paid. Many more companies are simply saying "no" today than were 10 years ago. Back then, "being hacked" was much more of a black mark on an enterprise's reputation than it has become today. I'm not happy that "being hacked" is almost becoming routine, but with cyber attacks having become a nearly daily occurrence, no one who is observing them from a distance much cares anymore. As a consequence, companies are just saying no to ransom demands, are putting out a press release to say they were hacked, coming up with some spin about how the bad guys didn't get everything, and offering their customers 12 months of free credit reporting. Nothing to see here, move along.

So, rather than just stumbling upon targets of opportunity, the bad guys have needed to find targets where the "apologize, obfuscate and move on" practice would not be available. And the confidential client data being retained by major deep-pocketed law firms fits that bill perfectly.

There's no doubt that Weil Gotshal & Manges knew that the disclosure of their client's data would result not only in massive reputational harm — which a law firm could ill afford — but also in a mass of breach of fiduciary responsibility lawsuits brought by their own current and past clients.

We know that the FBI and others would have cautioned the law firm over and over that there's absolutely no guarantee whatsoever that the bad guys will honor their side of the agreement by deleting the stolen data. But given \$2 billion dollars in annual revenue, a \$20 million dollar gamble, which is just a 1% tax on the company's annual income, when weighed against the alternative of absolutely certain disclosure of hugely damaging data — that's a bet that's entirely understandable.

As I've been observing, the **only thing** these foreign criminals care about is money. They could not possibly care any less about the actual data they've stolen from Weil Gotshal & Manges. They know that the only chance they have of reliably obtaining voluntary ransom payments from their victims is if those victims believe that their payment of ransom will result in the deletion of the stolen data so that it can never be disclosed. It may be a bargain with the devil, but it almost certainly paid off.

The takeaway here is the observation that the overall drop in ransom payment likelihood has predictably shifted the attacker's targeting to those specific enterprises, law firms being a perfect

example, that have the most to lose if their stolen data is publicly disclosed. Companies who merely have millions of small customer transactions are increasingly shrugging off such breaches as unfortunate but almost inevitable.

Yet another Cisco SD-WAN 0-day being exploited in attacks

If I were to share the news that another unpatched 0-day flaw in Cisco's SD-WAN manager was being actively exploited in the wild, you could be forgiven for thinking that perhaps you were listening to a previous podcast. But sadly, no. In their reporting on this latest re-run of a story that pretty much writes itself – you only need to change the date and tweak some CVE numbers – Bleeping Computer reminds us:

Last month, Cisco also tagged a maximum severity Catalyst SD-WAN Controller authentication bypass flaw (CVE-2026-20182) as an actively exploited 0-day to gain administrative privileges on unpatched devices. While Cisco has not yet released patches for today's most recent problem, on May 14th it advised customers to upgrade to the software that had been fixed for CVE-2026-20182.

In February, Cisco patched another Catalyst SD-WAN Manager information disclosure security flaw (CVE-2026-20133), which CISA flagged as actively exploited in late April, and, two weeks later, warned that two more flaws (CVE-2026-20128 and CVE-2026-20122) were being abused in the wild. In March, it also addressed and flagged a critical authentication-bypass vulnerability (CVE-2026-20127) that has been exploited in zero-day attacks since at least 2023.

Over the last several years, CISA has tagged 90 Cisco vulnerabilities as abused in the wild, four of them in Cisco Catalyst SD-WAN Manager and six others exploited by ransomware operations.

90 vulnerabilities in just the past several years abused in the wild. Cisco has certainly earned their reputation for providing hackers with a ready and, so far, unending supply of remotely exploitable security vulnerabilities. Two months ago, on April 7th, Cisco wrote:

For some time, we have been stress-testing our own products and infrastructure against the most advanced AI-powered security tools available, including Anthropic's latest unreleased AI model – Claude Mythos Preview. What we have found has been illuminating. Now the real work begins. AI-powered analysis uncovers data at a scale and depth that legacy frameworks were not designed to accommodate. This industry will recalibrate together, and Cisco is committed to leading that conversation.

I hope they mean it. I hope they really do suddenly care more than they have ever appeared to in the past. Perhaps something needed to make security much easier for them to deliver, and perhaps "AI" will be that something that's been missing. It's inexplicable to me how a company that's so important and has been such a leader could continue year after year to have so many damaging security problems. What is their culture? We'll recall that years ago they were surprised to discover that the firmware of their own machines had been shipping with embedded authentication credentials. Perhaps they are just really that crappy at doing software and the only reason they were ever on top was that they were first.

WordPress “Everest Forms Pro” sites under attack

I’ve mentioned before that my desire to host web forums required me to run a PHP interpreter on a GRC domain. Due to the long history of security incidents surrounding PHP the idea of that terrified me, and I was unwilling to allow any such server to share a network with the rest of GRC’s infrastructure. In other words, I took my own advice in the same way that I do for residential IoT devices, which is to firmly sequester the things whose security we have no control over on their own network. Fortunately, my choice of the PHP-based XenForo for forums and the PHP-based NeuvoMail for mailing has been solid... but I’m still not allowing anything that runs PHP anywhere near the rest of GRC’s network.

The reason I’m mentioning this is that, once again, a PHP-based 3rd-party Wordpress plug-in has come under attack, and the means by which the plug-in is being attacked is just so marvelously “PHP” that I wanted to share it.

Last Wednesday, the Wordfence Wordpress security company posted the news of this latest vulnerability which carries a 9.8 CVSS. Wordfence wrote:

On March 30th, 2026, we publicly disclosed a critical Remote Code Execution vulnerability in Everest Forms Pro, a WordPress plugin with an estimated 4,000 active installations. This vulnerability can be leveraged by unauthenticated attackers to execute arbitrary PHP code on the server, leading to complete site compromise. The vendor released the fully patched version on March 18th, 2026. Our records indicate that attackers started exploiting the issue on April 13th, 2026. The Wordfence Firewall has already blocked over 29,300 exploit attempts targeting this vulnerability.

Wordfence Premium, Wordfence Care, and Wordfence Response users received a firewall rule to protect against any exploits targeting this vulnerability on February 27, 2026. Sites using the free version of Wordfence received the same protection 30 days later on March 29, 2026.

Considering this vulnerability is being actively exploited, we urge users to ensure their sites are updated with the latest patched version of Everest Forms Pro, version 1.9.13 at the time of this writing, as soon as possible.

We’ve covered the work of Wordfence in the past and I have no problem allowing them to promote themselves by sharing their posting here since any site that has chosen to employ 3rd-party Wordpress plug-ins would be well served to at least run the free version and, if I were they, to pay something for added protection. In other words, these are good guys offering an important service.

Next, they explain what they found, writing:

Examining the Everest Forms Pro code reveals that the plugin uses the `process_filter()` function in the `Process` class to evaluate user-defined calculation formulas. The function concatenates submitted form field values into a PHP code string, which is then passed to the `eval()` function,

I’ll interrupt here to note that this is a variation of the infamous “Bobby Drop Tables” flaw. Any time any user-provided input is passed to any function that might confuse data with commands,

that user-provided input must be scrupulously sanitized to prevent malicious users from managing to use a web form for their own command input. Wordfence's write up continues:

Although user input is sanitized with `sanitize_text_field()`, this function does not escape single quotes or other characters that are significant in PHP code. For string-based fields (such as text, email, select, and radio fields), the submitted value is placed inside single quotes and directly added to a PHP code string. An unauthenticated attacker can exploit this by submitting a value containing a single quote, followed by malicious PHP code and a comment character, allowing them to break out of the string and inject PHP code that is later executed through the `eval()` function.

This makes it possible for unauthenticated attackers to execute arbitrary PHP code on the server by submitting a crafted value in any string-type form field, as long as the targeted form uses the "Complex Calculation" feature.

As with all remote code execution vulnerabilities, this can lead to complete site compromise through the creation of administrator accounts, the use of webshells, and other techniques.

This is exactly why PHP terrifies me. When I've made the mistake of stating that PHP is fundamentally insecure, well-informed listeners have written somewhat indignantly to argue that it's entirely possible to write secure PHP systems. I assume that's true, since I have never had any trouble with XenForo and their security record has been very good. Not perfect, but still very good. So I suppose a more balanced assertion would be that authoring secure PHP websites requires much more understanding of the security pitfalls inherent in the use of PHP than the typical PHP author possesses.

Wordfence explains what their Wordpress application firewall has intercepted, writing:

The most common payload observed in our blocked requests attempts to create a new administrator account named "diksimarina" on the affected site.

The attacker submits a value for a text field that begins with a single quote to close the wrapping string literal, followed by a PHP statement that calls `wp_insert_user()` to create a new administrator account with the username "diksimarina". The trailing `//` comment marker ensures the rest of the generated PHP code, including the closing quote, is treated as a comment and does not cause a syntax error. When the form is processed and the calculation is evaluated, the injected PHP code is executed and the malicious administrator account is created. Once authenticated as the new administrator, the attacker can fully compromise the site by uploading webshells, modifying themes or plugins, or installing further backdoors for persistent access.

So the problem with PHP is that while it correctly advertises itself as very easy to use, the less well appreciated fact is that it's also extremely easy to abuse.

Teens using WeedHack to attack each other

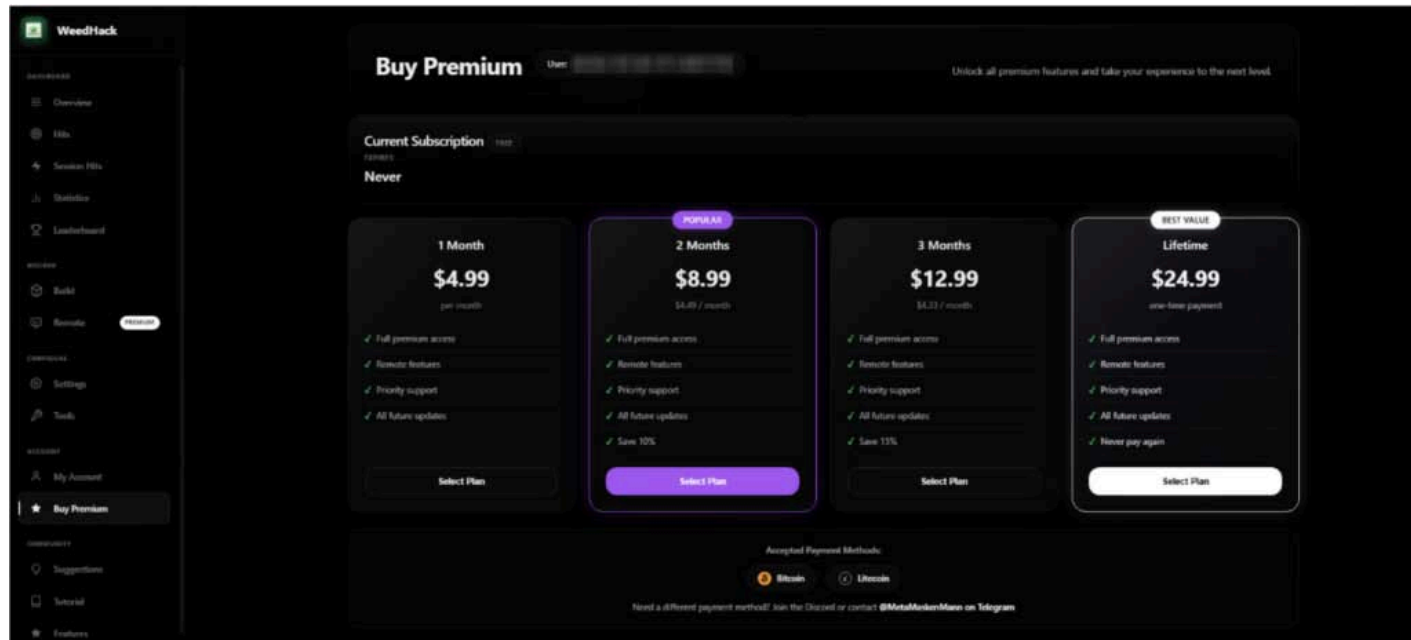
McAfee's report headline caught my attention because it said: *"New Malware Targeting Minecraft Infects 2000 Daily, and Teens are Becoming Attackers."* This is all pretty sad but it's worth us

knowing what's going on. McAfee writes:

McAfee Labs has discovered a massive, ongoing malware campaign called WeedHack that disguises itself as free Minecraft mods and game clients to infect players' computers. Since January 2026, it has logged more than 116,000 victim infections, averaging 2,000 to 3,000 new hits every single day. What makes WeedHack different from most malware is how cheap and easy it is to use. Typically, a hacker would pay hundreds of dollars per month to access attack tools through underground criminal networks. WeedHack offers a free version to anyone with a Discord account. A premium upgrade, which includes the ability to secretly watch victims through their own webcam, starts at just \$5 a month.

This low barrier has attracted a younger crowd of would-be attackers, many of them appear to be teenagers or young adults. Our researchers were startled to discover teens using these tools not just for financial theft, but to harass and bully their peers, a pattern we've documented and that makes this campaign especially concerning.

WeedHack is a Malware-as-a-Service (MaaS) campaign, meaning it's a criminal business that sells hacking tools to customers, the same way a legitimate software company sells subscriptions. The "product" is malware that gets secretly installed on a victim's computer when they download what they think is a Minecraft mod or client. Once installed, it can steal passwords, hijack accounts, and, for paying customers, it can give the attacker live access to the victim's screen, webcam, and files. The campaign operates a polished, professional-looking dashboard hosted openly on the Internet (not the dark web). That dashboard lets customers track their victims, download stolen data, and launch remote access features, all from a browser.



One of the most disturbing findings from our investigation is how WeedHack is being used. While monitoring the campaign's Telegram channel, which had over 850 members during the time of our research, we observed that many customers appear to be teenagers and young adults, and a significant portion are using the remote access tools not for financial gain, but to harass and intimidate other players.

We observed attackers recording victims through their webcams without consent and sharing those recordings in the Telegram channel as trophies. Others used knowledge of victims' IP addresses and system access to threaten them.

It's important to note that, at the current time of publishing, the Telegram channel has been taken down, and no replacement channel has appeared. McAfee is continuing to monitor any new channels that may be established by the threat actors for further communication.

Still, what we observed is a form of cyberbullying with unusually invasive tools behind it. If you or your child has been contacted by someone online claiming they have hacked your computer, have your webcam footage, or know your IP address, take it seriously.

- *Do not follow the attacker's instructions, it makes things worse*
- *Tell a trusted adult immediately (parent, guardian, school counselor)*
- *Contact your local law enforcement, this may constitute criminal conduct.*
- *Do not engage with the attacker or attempt to negotiate*

How Do People Get Infected? *WeedHack spreads in two main ways, and the campaign even provides its customers with step-by-step tutorials on how to carry out both.*

1. Fake YouTube Videos: Attackers create convincing YouTube videos reviewing or demonstrating Minecraft clients and mods. The videos are well-produced, some include voiceover narration, and link to malicious download sites in the description and comments. One video McAfee identified had over 7,500 views before being flagged. Comments are also sometimes planted by the attackers claiming the files are safe.

2. Fake Mod Websites: WeedHack instructs customers to build convincing-looking websites that mimic official Minecraft mod pages. These sites are deliberately designed to show up high in search engine results for popular mod names, a tactic called SEO poisoning. Some fake sites include fake security warnings, Discord links, and GitHub references to appear legitimate. In one case, a site warned players to "only download from us," while actively distributing malware. Minecraft clients and mods specifically targeted include: Meteor Client, Radium Client, Wurst Client, LiquidBounce, Impact Client, Future Client, and others.

What Happens When You're Infected? *Infection occurs in four stages that happen silently in the background after a victim opens the downloaded file:*

Stage 1 – First Contact: The malicious file launches quietly (without showing a console window), connects to a hidden network, and phones home to receive further instructions. It uses a sophisticated technique involving the Ethereum blockchain to locate its command server in a way that's difficult to block or take down.

Stage 2 – Taking Hold: The malware disables Windows Defender protections, gathers detailed information about the victim's computer (processor, graphics card, RAM, operating system), and takes a screenshot of their screen. It then steals Discord tokens, browser passwords and cookies.

Stage 3 – Digging In: The malware installs itself so that it automatically restarts every time the victim logs into their computer. It sets up a hidden scheduled task that runs continuously with highest system privileges.

Stage 4 – Full Access: For premium customers, an additional component is installed that connects the attacker to the victim's computer in real time. This includes live screen sharing with keyboard and mouse control, webcam access, keylogging (recording every keystroke), a reverse shell (full command-line access to the computer), and the ability to upload or download any files.

A separate component specifically hunts for Telegram credentials and cryptocurrency wallets, sending that data to a different server every five minutes.

What Can Attackers Steal? *The Free tier supports the theft of:*

- *Minecraft session IDs (used to hijack Minecraft accounts)*
- *Saved passwords and cookies from 36 different browsers*
- *Credentials from Discord, Steam, and Telegram*
- *Browser-based crypto wallets (56 supported) and desktop crypto wallets (12 supported)*
- *Files matching 24 different search keywords*
- *Screenshots of the victim's screen*
- *System information (computer name, IP address, hardware specs)*

And the premium tier adds:

- *Live webcam access*
- *Live screen sharing with keyboard and mouse control*
- *Keylogging (every key the victim types)*
- *Full remote shell (command-line control of the computer)*
- *File management (upload, download, delete files remotely)*

Okay. So just to be completely clear, what now exists is a service which, for as little as \$5 per month – apparently in a play for usage volume – anyone, and often teens, no longer need to have any – not any – hacking skills. All that has been done for them. They're able to subscribe to this new Malware as a Service out on the open public web and then trick others into downloading a Minecraft mod or client that gives them access to that infected user's saved passwords and cookies, their social media credentials, cryptowallets, and more. And the service is going gangbusters, logging between 2,000 and 3,000 new infected victims per day with more than 116,000 victim infections observed since this past January.

What have we done??

You know someone was bound to try it. So far, it's been contained inside a lab. Researchers with the University of Toronto and the Vector Institute wondered what an AI-powered network worm might look like and how effective it might be. So they made one. The paper they just published is titled: *"AI Agents Enable Adaptive Computer Worms"* and they explain: In our pursuit of new knowledge to enhance the security of artificial intelligence, we uncovered a cybersecurity threat with implications across society.

Since the idea of an AI-enhanced network worm is not a stretch, I'm just going to share the high points from the research overview they published. However, even this overview makes me somewhat queasy. Here's what they wrote:

Large language models (LLMs) now demonstrate the capacity for structured problem-solving that, combined with tool access, enables agentic AI systems to solve complex tasks. We show that when these capabilities are embedded in a self-replicating agent, they produce a fundamentally new cybersecurity threat: an adaptive computer worm that devises target-specific attack strategies to gain control of machines and spread across networks. Each compromised machine becomes part of the worm's own infrastructure, providing compute or reach for further attacks.

A computer worm is self-replicating malware that spreads across a network without human intervention. The WannaCry worm (2017) disrupted critical infrastructure across 150 countries by exploiting a single vulnerability. Traditional worms can be stopped by patching the specific vulnerability they exploit. Our adaptive worm cannot be stopped this way: it uses a recursive reasoning loop to detect and exploit diverse vulnerabilities as it propagates.

We demonstrate these capabilities in a controlled experiment: a prototype AI-driven worm powered by an open-weight LLM running locally, propagated across a heterogeneous network of Linux, Windows, and IoT devices with common corporate network vulnerabilities. The experiment was conducted in an isolated virtual network.

We believe this work highlights three important dimensions of the impact of AI on the cyberthreat landscape:

First: It establishes a qualitative shift in threat capability. *The worm replaces fixed exploitation code with goal-directed reasoning that adapts to the vulnerabilities of each encountered target in real time. Our agent self-replicates across networked devices, subverts control of systems, and self-sustains on stolen resources.*

Second: The AI-driven worm requires only an open-weight model that can run on a single, local GPU. *It does not rely on any commercial AI platform. This renders vendors' centralized safety controls, including service refusal, content filtering, and rate limits structurally irrelevant. The worm's tiered design, where each compromised GPU-equipped node provides reasoning for lightweight agents on downstream devices, extends the attack surface to any networked device.*

And, finally: The traditional economic barrier in cybersecurity collapses. *The worm parasitically uses the victims' own computational resources, reducing the attacker's marginal cost to zero. As consumer devices increasingly support LLM inference, the reasoning resources available to such adversaries grow accordingly.*

This work provides empirical evidence that autonomous cyberoffence has crossed from theoretical risk to demonstrated capability, a challenge that spans AI research, cybersecurity, and public policy. We believe this transition demands rigorous, transparent evaluation of model capabilities across the open and closed-weight model ecosystems.

I'm not sure what that conclusion was supposed to mean. They wrote "*We believe this transition demands rigorous, transparent evaluation of model capabilities across the open and closed-weight model ecosystems.*" What this actually means, and for the first time demonstrates, is that the defenders of cyberspace had better get serious about tightening up their code. This leaves the huge problem of the existing installed base of systems that are not going to update themselves, and will never be updated without some form of more than typical intervention.

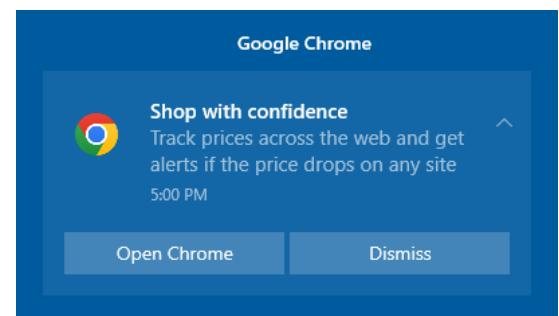
The one bright spot here is that (knock on wood) we seem to be past the frolicking days of uncontrolled Internet worms. Most mischief now is about bad guys focused upon making money, and Internet worms do not do that the way targeted extortion can. The place I can see a worm being deployed as an offensive cyber weapon is not by a criminal organization but by a nation-state like the U.S., China, North Korea or Russia. And in that case, its worm code would be carefully written to restrict its reach and spread to within a targeted geography.

So this feels more like an interesting academic exercise. This is not to say that someone might not release such a thing just to see what it can do. But as these researchers also noted, the world does not yet have sufficient potential victims with inference engines capable of supporting a roaming large language AI model. By the time that changes the world's exposed vulnerabilities should be so new that any potential worm would starve.

A Non-Sequitur

I'm rudely interrupting this podcast because my work on it was just now rudely interrupted by an unsolicited Win10 notification from Google Chrome. I wasn't using Chrome. I don't use Chrome unless there's no alternative. I haven't used Chrome in recent memory. Yet we know that today's web browsers are all running agents in the background which serve to keep themselves up to date. I'm all for that. But the operative phrase here is *"in the background."*

When Chrome, which I have installed but have not been using, without invitation pops-up a notification telling me to *"Shop with confidence"* and that I can *"Track prices across the web and get alerts if the price drops on any site"* – it's no longer *"in the background"*, it's an annoyance my foreground. The Internet appears to be silent on the issue so I don't know what's going on. Perhaps this is Google trying to get traction for some of its new agentic AI crap. In any event, I hope more than ever that Mozilla is able to somehow keep Firefox alive. A web browser is serious business and keeping one going, secure, and up to date with the never-ending and ever-changing world wide web consortium standards takes a huge amount of work.



HTTP/2 Bomb attack

It's been a while since the abuse of a core Internet protocol was able to take down a wide variety of servers. But the recently discovered – and very irresponsibly disclosed – HTTP/2 Bomb attack can knock down NGINX, Apache, IIS, Envoy, Cloudflare's Pingora and presumably any other modern web server that accepts and terminates HTTP/2 connections and queries.

An independent observer of this wrote: *"Since the bug is an HTTP/2 protocol bug, other services may also be affected. With Nginx (HW load balancers, the most popular open-source reverse proxy, ingress controller for Kubernetes), Envoy (reverse proxy for large cloud and tech companies such as Google, Amazon, Netflix, and Airbnb), and Azure's IIS, a large portion of modern public-facing web infrastructure is affected"*

And when they say "affected" they're not kidding. They added:

Given these circumstances, we had to take a close look at the writeup and assess the impact in order to determine which of our customers were affected and to incorporate the new attack vector directly into our platform. And, oh boy, that attack is effective! With one single notebook we were able to bring down ANY of our own HTTP/2 servers, small and large.

- *A single attacker can consume 20-30 GB of RAM on the target.*
- *RAM/memory remains locked even after the attack is stopped; this allows for a "low & slow" attack, in which the attacker starts with a low connections/streamrate but gradually consumes more and more of the target's resources over time.*
- *Once a certain RAM usage threshold is reached, the affected Nginx instance crashes and must be restarted via a hard reboot (permanent damage).*
- *With these attacks, even a small botnet of 10 bots can take down services of any size; for a low-and-slow attack with fewer than 10 RPS (requests per second) a botnet of only 100 bots is sufficient; such an attack would be undetectable and unstoppable by any web application firewall.*

Given the discovery of a truly devastating attack against pretty much all of the current Internet infrastructure, the fact that its discoverer chose to release the details without coordinating with the rest of the industry is truly unforgivable. We encountered "*Calif*" recently and I didn't think much of them. Now, unfortunately, I do think something of them, and it's not good. Their website's home page declares in large font type "*Pushing the frontier of vulnerability research with AI.*" and the sub-head: "*Leet hackers and top models, what could go wrong? Let's find out.*"

Their posting about this sets the tone for them and for their site. One week ago today on June 2nd their blob posting carried the title: "*Codex Discovered a Hidden HTTP/2 Bomb*" and they wrote:

14 years ago, I helped break HTTP header compression, then was asked to review the fix, which became part of HTTP/2. Life has come full circle: today we're releasing an attack I missed. We're publishing HTTP/2 Bomb, a remote denial-of-service exploit against most major web servers, including: nginx, Apache httpd, Microsoft IIS, Envoy and Cloudflare Pingora. The vulnerable behavior exists in each server's default HTTP/2 configuration.

The attack was discovered by OpenAI's Codex, which chained two techniques known to humans for a decade: a compression bomb and a Slowloris-style hold. The bomb targets HPACK, HTTP/2's header compression scheme: one byte on the wire becomes one full header allocation on the server, repeated thousands of times per request. The hold is a zero-byte flow-control window that keeps the server from ever freeing any of it.

A curious search on Shodan revealed more than 880,000 websites supporting HTTP/2 and running one of these servers, though many sit behind a CDN, which is much harder to bring down. A home computer on a 100Mbps connection can render a vulnerable server inaccessible in seconds. Against Apache httpd and Envoy, a single client can consume and hold 32GB of server memory in roughly 20 seconds.

They then get into the details of this potentially debilitating vulnerability that's sufficient for anyone proficient to design an attack. But wait!, that won't be necessary, because not only did these irresponsible jerks describe something for which they knew there was no current defense,

but they also published a fully working proof of concept exploit.

Not surprisingly, the folks over at Envoy, who produce the reverse proxy front-end used by companies such as Google, Amazon, Netflix, and Airbnb, were not humored by the behavior of these irresponsible glory hounds, so they posted to the feedback thread for this announcement blog posting. They wrote:

OP ignored responsible disclosure policy and released a 0-day for Envoy ecosystem. Envoy community was in process of releasing a patch for this problem:

<https://github.com/envoyproxy/envoy/security/advisories/GHSA-22m2-hvr2-xqc8>

The Calif guy replied:

Thanks for fixing the issue so quickly — this is a win for Envoy users. We believe the traditional disclosure model is increasingly outdated in the era of AI-assisted vulnerability discovery, and we explain our rationale for disclosure in the post.

Envoy replies:

And irresponsible disclosure is a huge loss for Envoy ecosystem and possibly wider industry. Did you disclose this to all H/2 implementations? This should have really been coordinated via VINCE to make sure all H/2 vendors are aware. And if the 90 day disclosure policy is outdated, what is the new policy that you believe is appropriate? You have filed advisory on May 27th and published this blog on June 2nd. Is your new embargo policy 4 days?

Calif finishes with:

We disclose details once we believe that anyone monitoring public commits could reproduce the issue using AI-assisted analysis. In our view, withholding information after the relevant commits are public does more harm than good. We recognize that reasonable people may disagree, and we respect that perspective.

What a mealey-mouth position. I suppose we're going to be seeing more of this sort of thing as those who could not have discovered this attack on their own use AI to find the attacks for them. In the era before AI, acquiring true expertise would generally be accompanied by the acquisition of maturity. But when some AI hands someone who has never done the hard work, they haven't the maturity to guide their handling of such a gift. In this case it is utterly unconscionable that this exploit would be publicly posted without a far more widely coordinated private disclosure.

Nginx has scrambled to assemble a patch and has made it available through standard update channels. Apache's fix exists in a standalone module but has not yet been bundled into any release that package managers will pick up. Microsoft IIS has no patch and no CVE has even been assigned to the IIS variant yet. And we know that Envoy has also scrambled.

As I said, I suppose we're going to be seeing more of this sort of thing in the future. I'm not unhappy that I'm still running an HTTP/1.1-only web server. I'm sure that by the time I'm ready to deploy GRC's next servers Microsoft will have updated IIS. But in the meantime, what a mess!

Human or Bot?

Are you a person?

I've mentioned that I'm currently working to reduce the purchase friction for GRC's software by supporting a range of one-click purchase options such as PayPal, Google Pay, Apple Pay, Venmo, etc. Since my plan is to create a few more low-cost commercial products before I plow back into SpinRite for Windows, I want to make purchasing those as simple as possible. So I've been working to upgrade the eCommerce system I wrote 22 years ago.

I briefly flirted with the eCommerce provider "Stripe" since I liked their integration solutions, but I decided to go another direction. But during that brief flirtation they got hold of my email address, so I've been receiving occasional notes from "Chet" at Stripe reminding me how wonderful they are. Every email from "Chet" contains a link inviting me to set a time to further discuss the various wonders of using Stripe. I've been ignoring them and letting them go unanswered until this past Sunday evening when I decided to explain to Chet that since they do not support PayPal payments Stripe is a non-starter for me.

Yesterday (Monday) morning a reply was waiting for me informing me of the good news that Stripe did support PayPal payments so that, as the email put it, it didn't need to be one or the other. And, as with every email, it quickly ended with a link to "book a time" for a Stripe discovery call.

What I had failed to mention to "Chet" was that I needed to have **everyone** able to use PayPal, including U.S. domestic purchasers. That's not something PayPal allows for anyone else. After jotting a short note back to "Chet" I was hit by the question: "Am I interacting with a person?" Is there actually any "Chet" at the other end of this email dialog? I realized that it's entirely possible that all of this sort of front-end sales lead development has already been automated by AI. I'm being pushed by automation to click a link to make an appointment with a real person... and the cost of that "pushing" from the pusher's end may have been reduced to zero. Now, all of the cost of that interaction is at my end. It's actually a new form of business spam.

And it's becoming prevalent because one of the things I've been noticing is the degree to which an increasing percentage of business operations are being outsourced. When I was interacting with DigiCert a few months ago, many of the links which looked like theirs actually pointed to salesforce.com. DigiCert is outsourcing a large chunk of their customer service communication handling.

A consequence of this increasingly prevalent outsourcing is that the degree of what I'd call "presence broadcasting" has been steadily increasing. In the good old days, when a company needed to design and develop their outward facing communications for themselves, everything was bespoke, varied and minimal – being only what really made sense for them. But now, when a company signs up, for example, with Salesforce, they simply check off all of the various crappy outreach services they want to offer – and subject everyone they can find to – and the service provider makes it happen. And today, we add to that a patient, never-tiring, proactive emailing AI agent to have zero-cost conversations as a means of "working the phones", or in this case the email. It seems clear that many businesses are soon to become much more annoying.

The Malicious Use of AI

We all knew it was coming, but it's no longer "coming". It has arrived. Last Wednesday, Anthropic published a red team report which examined the detected abuse of their Claude AI by malicious actors. We need to examine and understand how AI is being used to further the nefarious ends of those who would do us harm. The report's three authors opened their report by writing:

We've spent the past year investigating how threat actors are weaponizing AI to conduct cyber operations. Today, we're sharing a new analysis that maps these real-world attacks onto the MITRE ATT&CK® framework, a database of tactics and techniques used by cyberattackers. Doing so reveals patterns that challenge traditional assumptions about cybersecurity—for example, that the level of risk a threat actor poses can be assessed via metrics like technical sophistication or breadth of techniques. We partnered with Verizon to include some of these results in the 2026 Verizon Data Breach Investigation Report (DBIR), and are publishing this report to offer a longer-form analysis of trends we are seeing in AI-enabled cyber operations.

In what I'm about to share from their report you hear these researchers referring to "accounts". The "accounts" Anthropic is referring to are Claude AI accounts whose holders were attempting to use their access to Claude AI for malicious purposes.

The other key to understanding their work is the MITRE ATT&CK framework which we've never had the occasion to look at closely. The MITRE ATT&CK homepage explains:

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community. With the creation of ATT&CK, MITRE is fulfilling its mission to solve problems for a safer world — by bringing communities together to develop more effective cybersecurity. ATT&CK is open and available to any person or organization for use at no charge.

MITRE's ATT&CK database is really nothing more than a well thought out and carefully constructed taxonomy of all the various things bad actors have been seen to do through the years. So, for example, it first breaks malicious conduct down into 15 individual categories. Those are: Reconnaissance, Resource Development, Initial Access, Execution, Persistence, Privilege Escalation, Stealth, Defense Impairment, Credential Access, Discovery, Lateral Movement, Collection, Command and Control, Exfiltration and Impact. Then, each of those broad categories of malicious conduct is further broken down into a specific behavior. So, for example, taking the first category of "Reconnaissance", that's broken down into the 12 specific techniques of: Active Scanning, Gather Victim Host Information, Gather Victim Identity Information, Gather Victim Network Information, Gather Victim Org Information, Phishing for Information, Query Public AI Services, Search Closed Sources, Search Open Technical Databases, Search Open Websites/Domains, Search Threat Vendor Data, and Search Victim-Owned Websites.

So MITRE's ATT&CK taxonomy is a widely agreed-upon system for categorizing and naming any and all specific malicious activity across the spectrum, and it makes sense that this is what the Anthropic team would use to unambiguously communicate the specific patterns of abuse they've observed criminals attempting with their Claude AI service accounts. Here's what we know from their examination. They write:

For this study, we analyzed 832 accounts associated with malicious cyber activity over the course of one year, from March 2025 to March 2026. Anthropic banned these accounts from using Claude for violating our Usage Policy. The accounts in this analysis are just a subset of those we investigated and banned during this time period; we selected them because we had enough detail about their malicious activities to map their techniques onto the MITRE ATT&CK framework.

*The 832 accounts in our analysis used AI models for all 14 tactics and 482 unique sub-techniques across the framework, from initial reconnaissance through final impact. We also developed a risk-scoring framework to assess how much AI assistance **helped** these actors plan their attacks. Most strikingly, we found that the percentage of actors labeled as being medium or higher risk, jumped from 33% up to 56% between the first and second halves of the year. **This suggests that AI is helping attackers conduct increasingly sophisticated cyber operations with greater ease.** Our analysis resulted in three key findings:*

First: *The number of actors using AI for cyber operations is growing, and their actions carry higher risk. As mentioned above, the percentage of medium- or high-risk actors increased by a factor of about 1.7 in under a year, from 33% during the first half of our study window to 56% during the second. That growth is concentrated in actors using AI for some of the most harmful activities, including lateral movement, credential dumping, and web shells — that carry the highest per-actor risk weight in our scoring, rather than the commodity build-and-obfuscate work that dominates the rest of the population. Traditionally, only the most technically sophisticated actors could operate across the entire killchain, or the sequential stages of a cyberattack. But our analysis found that this is no longer the case. The platform through which they access the model (such as an API or an agentic coding platform like Claude Code) also has no bearing on how high-risk their actions are. What does distinguish the highest-risk actors is which techniques they're asking the model for.*

Second: *Agentic scaffolding will make it possible for cyberattacks to be far more autonomous. As AI-enabled cyber techniques become more common among this population, it will become harder to differentiate an actor's risk level based on what they are asking a model to do. Instead, the differentiator will become the scaffolding—the surrounding code, architecture, and tooling that makes AI models more capable—that actors build around the model so they can chain together attack stages autonomously. This was starkly apparent in the cyber espionage campaign we disrupted in November 2025, which had a maximum risk score of 100 yet only used a number of techniques comparable to medium-risk actors. That attack was distinct not because of the number of techniques it employed but because of how the attackers used an AI agent to orchestrate them.*

Third: *The MITRE ATT&CK framework does not yet cover the autonomous actions that make these actors so dangerous. Autonomous killchain orchestration, real-time pivot decisions, and AI-directed execution with no human intervention do not yet have ID numbers in the ATT&CK framework. Our report included 13,873 observations of malicious activity, all of which mapped to categories laid out in the framework—but the behaviors that distinguish the highest-risk*

*actors, and determine the speed and scale of their operations, do not yet have such IDs. The taxonomy that modern threat intelligence relies on must be evolved to capture them. While Claude Mythos Preview demonstrates where frontier AI cyber capabilities are heading—models able to find and exploit vulnerabilities at a level approaching the most skilled human researchers—this report tells us how threat actors are already misusing **generally available models** today. It also serves as a guide to how threat actors are likely to misuse increasingly capable models in the near future, giving defenders a chance to get ahead of them.*

What we learned from this and other analyses directly shapes how we build Claude to prevent such misuse. For example, we've updated the classifiers built into Claude to detect the highest-risk actors, and have expanded our probe detections to cover high-risk behavioral indicators revealed by this analysis. These findings point to a landscape where the dividing line between low and high-risk actors is no longer technical skill but orchestration, and where defenses, detections, and the shared frameworks we all rely on will need to evolve as fast as the attacks they describe.

Okay. There is so much here. No one who has been following this podcast has ever heard me run around saying that the sky is falling. But what we learn from this report is as close to that as we've ever been. This extremely sobering report shows that while we have been focused upon and enraptured by all of the many productivity benefits the use of LLM AI can bring to our lives, malicious actors have been exploring the many ways the same power can be used to attack our world — and there are many. The extreme leveraging power of AI cuts both ways.

During the many years of this podcast before AI, our longtime listeners will have often heard me suggest that all major cyber-powers must have assembled, be maintaining and growing a large database of known vulnerabilities. The database will be large because there are so many known vulnerabilities. My thought was always that when a nation-state actor wanted to attack someone specific they would determine which equipment and versions were being used, lookup the known vulnerabilities in their carefully curated master vulnerability database and launch their attack.

But, as it turns out, that's not the way it's going to happen. Instead, all of the well meaning security researchers and software publishers around the world have been publishing all of this information for decades. And thanks to AI model training it doesn't need to be curated into any reference database. Instead, any well-trained malicious AI will have absorbed all of that knowledge and will have it at the tip of its virtual fingers when it's asked to attack a target.

The most important point to appreciate is that bad guys are only using publicly available cloud-based AI, such as Claude, GPT or Gemini, because we're still in the very earliest days of where this is all headed — it has not really yet begun — legs are still being stretched. Widely available public cloud-based AI services are investing a tremendous amount of time, effort and resources erecting, maintaining and refining guardrails around their AI because they have no choice; they **must** do everything they can to prevent the abuse of their publicly available services. And the essential nature of LLM-based AI means that even that is not easy.

But we already know that AI is able to run quite well off the cloud, locally, on local hardware. And such AI will have no safeguards or guardrails of any kind to limit its actions. In the very near future, it will be local models that the malafactors will be employing to direct their real-time attack campaigns. While it's against my nature to warn that the sky is going to fall, in the near

future I'm not sure I'd want to be spending too much time out in the open. We have far too much legacy mess to clean up and not nearly enough time or incentive to do it. We're in trouble. The bad news is that once attackers move to the use of their own local AI, our ability to monitor their actions at the AI prompt level will disappear. But the good news is that, as Anthropic's year-long study shows, this has not happened yet; so we're able to see what these miscreants have been up to. Anthropic writes:

The findings in this report are drawn from 832 accounts that Anthropic banned for violating cyber-related parts of our Usage Policy between March 2025 and March 2026. We identified these accounts through a combination of automated safeguards and investigations by our Threat Intelligence team. For each account, we produced a summary of the observed activity. We then extracted the tactics, techniques, and procedures (the "TTP"s) described in those summaries, and mapped them to the version of the MITRE ATT&CK framework that was live at that time, which was v18. In all, we observed 13,873 actions across 482 unique techniques and all 14 ATT&CK tactics.

We gave each actor a risk score from 0 to 100 (with 0 being the lowest risk and 100 being the highest) based on a new methodology we've developed called the AI Risk Enablement Score (ARIES). We've anonymized the data so that actors cannot be identified in the analysis that follows.

I'm going to skip past the description of their scoring system because the most interesting part of Anthropic's report is what they learned of the way threat actors are using – well, abusing – AI today. They wrote:

Our empirical analysis of 13,873 observed techniques reveals clear patterns in how adversaries are using AI across the attack lifecycle, and the most common techniques that models are being used for today.

The most common technique family we observed was "Develop Capabilities" used by 574 of the 832 actors in our analysis, or 69%. The majority of this behavior manifests as "Malware Development", used by 560 actors. In practice, we observe threat actors misusing models to build and refine custom scripts to run, write DLL injection code with detailed guidance on how to implement it, as well as canvas fingerprinting evasion and automated account management.

The next most prevalent techniques are "Obfuscated Files or Information" employed by 64.7% of threat actors; "Data from Local System" employed by 55.9% of threat actors; and "Impair Defenses" employed by 54.9% of threat actors. Together, these top techniques show that threat actors most commonly seek LLM's help to build pre-engagement offensive tooling, make those tools harder to detect, and harvest data from compromised systems.

On the other hand, actors are much less likely to use LLMs for real-time, adaptive decision-making once they've gotten inside a target network. For example, only 54 of 832 threat actors (6.5%) used models for lateral movement, and less than 12 actors used models for remote services like RDP, SSH, and SMB. Only 22.5% of actors use LLMs for privilege escalation and impact stages.

Some technique families that are staples of real-world cyberattacks—such as active directory exploitation, Kerberos ticket attacks, cloud infrastructure manipulation (AWS, Azure, GCP), and

container escape —have notably lower representation within the dataset.

One observation I have is that Anthropic's view of what the bad guys are doing is certainly skewed by the fact that their AI is deeply wrapped in guardrails. So the lack of more sophisticated use of AI's potential is likely a combination of the resistance the cloud-based services already have against abuse coupled with how early we still are in this game. The strongest supporting evidence for this is the fact that Anthropic noted the large jump in their own risk assessment of bad actors — a jump from 33% to 56% in half a year suggests that we are far from having reached any sort of steady state. They continue:

The top techniques and the frequency with which actors used them didn't change much over the one-year period we studied. For both the first and second halves of the period, the median number of techniques the model is used for is 16. In the second half of the year, we observe a subtle directional shift, with threat actors using models less to build standalone malware or obfuscation scripts and more to help with specific operational phases in a cyberattack, and for on-target discovery and collection techniques. Specifically, we observe an 8.9% increase in "Account Discovery" occurrences, as well as a 6.2% increase in "Automated Exfiltration", alongside a 12% decrease in "Develop Capabilities" and a 8.6% decrease in "Phishing".

***"Defense evasion"** is the single largest tactic category in the dataset, present in the behavior of 84.4% of the actors we studied. MITRE defines 64 techniques under "defense evasion" across its Enterprise- and Mobile-specific frameworks; we observe 32 of these techniques in our dataset: 25 for enterprise and 7 for mobile. The top techniques observed within this tactic include:*

"Obfuscated Files or Information": 64.7% of threat actors in our sample used AI to implement techniques like XOR/base64 encoding, polymorphic variants, and anti-detection wrappers to evade signature-based detection.

"Impair Defenses": 54.8% of the threat actors studied used AI to bypass, disable, or tamper endpoint security tools.

"Process Injection": 30.3% of actors used AI to write malicious code that could be injected into legitimate processes, such as process hollowing and DLL injection, to execute payloads from trusted process memory.

Less frequently used tactics include impact (2.8%), exfiltration (2.8%), privilege escalation (2.4%), and lateral movement (0.7%). Together, these account for just 8.7% of all observations—less than defense evasion alone. Since these actions all occur later in the attack life cycle, this suggests that threat actors are using models more in the early stages of an attack and less in the later stages—that is, once they have infiltrated a network and are adapting to conditions in a live environment. This pattern remained stable over the one-year period we studied.

While tactics such as lateral movement are much less prevalent in our dataset, they are highly correlated with the highest ARIES risk scores—meaning that the highest-risk actors are also the ones most likely to use models for the later stages of a cyberattack. Actors who use AI to perform lateral movement have risk scores that are, on average, 10.5 points higher than actors who do not use AI tools in this way. This suggests that going from using AI to prepare for a cyberattack to using it to take actions in live network operations is a key marker of high

AI enablement.

Overall, the actors with the highest risk scores used AI most heavily for post-compromise, hands-on-keyboard techniques, such as remote services, credential dumping, web shell deployment, and internal network and account discovery. Lateral movement was the strongest marker of a high-risk actor: the 54 actors in our dataset who used lateral movement had an average risk score of 56.4, nearly 10 points above the mean of 46.8. No other technique came close to having such predictive power.

At the technique level, the techniques that were most commonly used by the highest-risk actors were "Remote Services: SSH/SMB", "Valid Accounts", "OS Credential Dumping", "Archive Collected Data" and "Web Shell". These were all three to five times more common among the highest-risk actors compared to the overall population.

Meanwhile, the most ubiquitous tactics (such as defense evasion and resource development) and commodity techniques (such as credential stuffing and spearphishing) were used at roughly the same frequency by both the highest- and lowest-risk actors, which is unsurprising given that these tactics are so common. Taken together, the data suggests that the majority of threat actors are using AI to build artifacts like malicious code in the preparatory stages of an attack, but the highest-risk actors are using models both in the preparatory stages of an attack as well during the hands-on work inside a compromised network.

We also found that the attributes that threat-intelligence teams typically lean on to assess threat actors—such as their assessed technical skill, choice of interface, or number of techniques used—are weak predictors of how much uplift an AI model might provide to a given threat actor. Technical sophistication, once removed from the composite score only very weakly correlates with the remaining risk components. In fact, removing this characteristic entirely leaves the top six actors in identical rank order. The high-risk tail is not an artifact of the Technical Sophistication component.

The correlation between breadth of technique coverage and risk score is also only weakly positive. Most actors are using the models for a smattering of techniques – in fact, the median actor in our dataset deployed 16 distinct MITRE ATT&CK techniques—a breadth that, five years ago, may have signaled a well-resourced, technically mature operation.

Lastly, interface choice tells a similar story — 80% of the actors in this study misused Claude Code, making agentic tooling the default mode of access rather than a distinguishing one, and actors restricted to the conversational interface, the API, or agentic coding tools converge on statistically indistinguishable risk profiles.

What this tells us is that the malicious actors who get the most uplift from AI are not necessarily more technically sophisticated than other actors, nor do they necessarily use coding tools or use Claude across multiple steps of the killchain; rather, they simply used Claude for more hands-on techniques.

As noted earlier, the share of actors scoring medium-risk or higher on AI enablement grew from roughly 33.5% in the first six-month period of the study to roughly 56.1% in the second—a 1.7x increase in under a year. The cohort shifted between these two periods by about 22.6 percentage points: while the majority of actors had a low risk score in the first six-month period, the majority had a medium risk score in the second six-month period.

While improved threat detection techniques may have contributed to this increase, we also see an increasing number of actors asking the model for more operational, in-network work that used to appear only in a much smaller cohort of high-risk actors. In the second six-month period of the study, we saw more specialized actors using models to build exploitation tooling, command and control infrastructure, and remote access trojans—but we also saw more low- and mid-skill actors using models not just for preparatory tasks but for live operations. The 8.9% increase in "Account Discovery" and 6.2% increase in "Automated Exfiltration" techniques we observed from the first six-month period to the second are consistent with this: the techniques that are becoming more frequent are the ones that imply the actor has already accessed the network.

The aspect of this entire study that's most unclear to me is how these researchers avoided the problem of altering the behavior of their abusers. They are describing wide ranging malicious activity that they apparently directly observed. So does that mean that they allowed Claude to perform these services for the bad guys? Did they drop their guardrails in order to see what the bad guys would do? That seems difficult to imagine. But if they did not, then those attempted malicious actions would have been automatically detected and blocked?

In any event, what we're learning from Anthropic's threat intelligence team is certainly interesting. Having examined what it happening, they then switch to what this means, writing:

What this means for defenders: the population of AI-enabled actors is not only growing but also drifting towards the riskiest activities in our framework, without requiring the actors themselves to become any more skilled. If this trend continues, these operational techniques will not be a differentiating factor anymore and will become the baseline tomorrow — and we'll need to find a new way to measure the riskiest actors.

Looking at our highest-risk threat actors also underscores that calculating the risk of AI-enabled cyber operations based on number, type, or breadth of attack techniques is insufficient. We need a way to understand the scaffolding threat actors are able to build to chain these techniques together to use in live operations. This will allow them to use AI models to autonomously execute large swaths of a cyberattack without human intervention.

We analyzed the behavior of the threat actor who orchestrated the AI-enabled cyber espionage campaign we reported on in November 2025, labeled GTG-1002, we see that this actor achieved the maximum possible risk score of 100, successfully compromised government and critical infrastructure targets across multiple countries, and developed a scaffolding to use Claude Code not as an advisor, but as an autonomous operator. Yet their overall MITRE profile—30 techniques across 13 tactics—is comparable to dozens of medium-risk actors in this dataset. The median actor deploys 16 techniques; several low-risk actors also exceed 30. In other words, technique count or tactic type alone could not explain what made GTG-1002 the highest-risk actor we have observed thus far.

What does explain this actor's high risk score is the increasingly agentic components they used: how they were able to orchestrate and chain together techniques to take action on their objectives. GTG-1002 weaponized Claude Code running on a Kali Linux machine, integrating open-source penetration testing tools as MCP (Model Context Protocol) servers—effectively turning the AI into an autonomous attack platform rather than a code-writing assistant. The AI didn't just suggest commands or generate attack scripts; it executed them and reasoned about attack environments autonomously. Some indications of their 'agentic-ness' show up proxied

through the types of techniques we track; GTG-1002 employed operational techniques such as "Remote Services: SSH", "Exploitation of Remote Services" and "Archive Collected Data".

Their analysis concludes with a very clear description of what they observed this most advanced threat actor, codenamed GTG-1002, doing. And if you want a chill to run up your spine, just remember that we have still barely begun and that what may be a single top-rated risk profile actor will almost certainly become every threat actor once the understanding of how to best leverage these new tools becomes widespread, as we certainly know it will.

So Anthropic explains what this one actor, GTG-1002, did:

- **Autonomous execution within stages:** *GTG-1002 deployed Claude Code running on a Kali machine to orchestrate dozens of MCP tool operations autonomously — scanning and mapping dozens of internet-facing services during reconnaissance, then discovering internal admin portals, databases, logging servers, and temporal workflow systems once inside the network. The AI didn't just suggest commands; it executed them, making tactical decisions about what to probe next without waiting for operator input.*
- **Live exploitation and pivoting:** *Operating within GTG-1002's scaffolding, the AI exploited an SSRF vulnerability in a public-facing web server to proxy commands into the internal cloud environment, harvested SSH private keys from internal infrastructure and service account tokens from cloud metadata services and AWS Secrets Manager, and used those harvested credentials to move laterally across the victim's cloud environment. These are the operational phases (discovery → credential access → lateral movement) that were more rare in our dataset.*
- **Human intent, AI execution:** *GTG-1002 provided strategic direction while the AI handled tactical implementation. The AI operated autonomously during reconnaissance and internal discovery, adapted its approach when it encountered unanticipated infrastructure like container image signing workflows and service account identities. It staged and compressed tens of thousands of proprietary workflow records and internal architecture documentation for exfiltration. The final data extraction — downloading to the attacker's machine via curl MCP tool calls — was human-directed, suggesting the operator retained control over the consequential decisions while delegating the operational work to the AI.*

GTG-1002's activity was novel for using an AI agent to autonomously chain together many stages of the cyberattack lifecycle—reconnaissance, exploitation, lateral movement, and exfiltration—into a coherent operation, making real-time decisions about what to do and what data to collect. This is the dimension of AI-enabled uplift that a technique-frequency table cannot capture, and it is the dimension we expect to matter most as agentic tooling matures.

We good guys are currently excited about the promise of using the awesome leverage of agentic AI to transform our lives for the better. But we should also soberly recognize that malicious forces throughout the cyberworld are every bit as excited by the capability they are also now receiving to dramatically magnify the power of their cyber attacks. This new AI technology is neither good nor bad itself. What it is, is a great deal of both.

